Phishing Email Detection & Awareness System

Cybersecurity Internship | Task 2 | Project Documentation

PROJECT **Phishing Email Detection & Awareness System**	**DOMAIN** **Email Security / Threat Analysis**
PROGRAM **AICTE Cybersecurity Internship**	**TASK** **Task 2 — Analysis & Reporting**
DATE **April 2025**	**STATUS** **Complete**

This document provides complete technical and analytical documentation for the Phishing Email Detection & Awareness System project, submitted as Task 2 of the AICTE Cybersecurity Internship Program. It covers the project objective, methodology, tools, findings, risk classification, prevention guidelines, and deliverables.

1. Project Overview

1.1 Background and Purpose

Phishing is currently one of the most prevalent and financially damaging cyber threats faced by organisations worldwide. According to IBM's Cost of a Data Breach Report, the average cost of a phishing-initiated breach stands at **$4.9 million**, and over **91% of all cyberattacks** begin with a phishing email. What makes phishing particularly dangerous is not technical sophistication — it is the deliberate exploitation of human psychology.

Attackers design phishing emails to trigger emotional responses: fear of losing account access, urgency to act before a deadline, or the authority of a message appearing to come from a bank or government agency. These psychological triggers bypass rational judgment and cause users to click malicious links, download infected files, or surrender login credentials without realising the threat.

This project was undertaken as Task 2 of the AICTE Cybersecurity Internship to develop practical, analyst-level competence in identifying, classifying, and communicating phishing threats — and to produce a client-ready awareness resource that any business can deploy to protect its employees.

1.2 Objectives

The project was designed to achieve five specific goals that mirror the responsibilities of a junior Security Operations Center (SOC) analyst.

- Analyze real-world phishing email samples using structured investigative methodology.
- Identify phishing indicators across four categories: sender and domain, content and language, links and URLs, and email metadata.
- Classify each email's risk level using a documented, reproducible scoring framework.
- Explain phishing attack mechanics in plain, accessible language suitable for non-technical employees.
- Produce a professional awareness report and complete project documentation that businesses can directly use.

1.3 Scope

The analysis was conducted on three synthetic phishing email samples representing a spectrum of risk levels — one confirmed high-risk credential-harvesting attack, one medium-risk suspicious email impersonating a known brand, and one low-risk borderline spam message. All analysis was performed using passive investigation techniques only; no malicious URLs were visited and no attachments were opened or executed.

NOTE This project is security education and analysis — not hacking or penetration testing. All samples are synthetic or publicly documented examples used strictly for educational purposes. No real credentials, real user data, or live malicious infrastructure were involved.

2. Tools Used

All tools used in this project are publicly accessible, free to use, and require no account registration unless otherwise noted. The selection reflects industry-standard practice for email threat analysis at the SOC analyst level.

2.1 Email Header Analysis

Email headers are the hidden metadata layer of every email — they record the routing path from sender to recipient and carry authentication results that reveal whether the email is legitimate. Two complementary tools were used for header analysis.

Tool	Primary Use	URL
Google Admin Toolbox — Message Header Analyzer	Parse headers, trace the Received chain, visualise delivery timeline and relay hops	toolbox.googleapps.com/apps/messageheader/
MXToolbox Email Header Analyzer	Verify SPF, DKIM, and DMARC authentication results; flag authentication failures	mxtoolbox.com/EmailHeaders.aspx

2.2 Domain and URL Inspection

URL and domain inspection was conducted entirely through passive reputation analysis. No suspicious URLs were visited directly in a browser. Each tool below was used for a specific layer of the domain investigation process.

Tool	Purpose	URL
VirusTotal	Check URLs and domains against 70+ security engine databases simultaneously	virustotal.com
URLVoid	Domain reputation scoring and blacklist verification across 25+ engines	urlvoid.com
URLHaus (abuse.ch)	Query known malicious URL and malware payload database	urlhaus.abuse.ch
WHOIS Lookup	Check domain registration date, registrant country, and hosting provider	whois.domaintools.com

2.3 Report and Documentation Generation

Tool	Purpose
Python 3.11	Analysis scripting, automation, and PDF report generation pipeline
ReportLab	Professional multi-section PDF generation with structured tables, headers, and footers
Node.js / docx.js	Word document (.docx) generation for project documentation

3. Analysis Methodology

The analysis followed a seven-step process modelled on real Security Operations Center workflows. Each step builds on the previous one, moving from raw evidence collection through to finished deliverable production. This structure makes the methodology reproducible — any analyst can apply it to a new suspicious email by following the same sequence.

Step 1 Sample Collection: Three synthetic phishing email samples were selected to cover a meaningful range of risk levels: one confirmed high-risk credential-harvesting attack, one medium-risk brand impersonation, and one low-risk unsolicited offer. Raw email text and headers were preserved verbatim as plain-text evidence files, with analyst notes appended in a clearly separated section. The original email content was never modified, ensuring evidence integrity.

Step 2 First-Pass Manual Review: Before applying any tools, each email was read manually and first impressions were recorded. This mirrors the experience of a non-technical employee receiving the email and ensures the psychological impact is documented. Questions addressed at this stage included: Who does this email claim to be from? What is it asking me to do? What emotion is it trying to trigger? Does anything feel wrong?

Step 3 Email Header Analysis: Full email headers were extracted from each sample and submitted to Google's Message Header Analyzer and MXToolbox. The Received chain was traced from origin to delivery, the originating IP address was noted and geolocated, and the Authentication-Results block was examined for SPF, DKIM, and DMARC outcomes. All findings were recorded in the evidence/header-analysis directory of the project repository.

Step 4 Sender Domain and URL Inspection: Each sender domain and every URL embedded in the email body was inspected using WHOIS (domain registration age), VirusTotal, URLVoid, and URLHaus. Domains registered within 30 days of the email send date were flagged as HIGH risk. URLs were checked for HTTPS usage, domain mismatch with the claimed brand, URL shortener usage, and presence in known malicious URL databases. No URLs were visited directly.

Step 5 Indicator Identification: All detected anomalies were catalogued under four categories: Sender and Domain, Content and Language, Link and URL, and Metadata. Each indicator was assigned a risk weight based on its contribution to phishing confidence: HIGH indicators contribute +3 points, MEDIUM contribute +2 points, and LOW contribute +1 point. The complete indicator list for each sample is preserved in the analysis directory.

Step 6 Risk Scoring and Classification: Point totals from the indicator analysis were applied to a three-tier classification framework: 0–3 points is Low Risk, 4–7 points is Suspicious, and 8 or more points is Phishing. An override rule was applied separately: any email containing a confirmed malicious payload or active credential-harvesting link is automatically classified as Phishing regardless of its point total.

Step 7 Report and Documentation Production: All findings were compiled into a client-ready PDF awareness report using Python and ReportLab, and into this Word documentation file using Node.js and docx.js. The PDF report targets two audiences: security analysts who need detailed indicator tables and scoring breakdowns, and non-technical employees who need a plain-

> language explanation of phishing, practical prevention tips, and a quick-reference Do's and Don'ts card.

4. Email Sample Evidence

Three email samples were analyzed, each representing a distinct risk tier. Every sample is preserved in the project repository under evidence/sample-emails/ as a plain-text file with analyst notes appended. The annotated content of each sample is reproduced below.

4.1 Sample 01 — High Risk (Confirmed Phishing)

SAMPLE EMAIL — HIGH RISK	
From:	security@secure-account-verify.com
To:	user@company.com
Subject:	Urgent: Your Account Will Be Locked
Date:	Thu, 10 Apr 2025 02:14:00 -0700
Body:	Dear User, We noticed suspicious activity on your account. To avoid account suspension, please verify your details immediately. **Verify Now: http://secure-account-verify.com/login** Failure to verify within 24 hours will result in a permanent account lock. Regards, Security Team

Risk Classification: PHISHING — HIGH RISK | Score: 14 points | 10 indicators detected

This email employs five of the six core phishing psychological triggers simultaneously: fear (permanent account lock), urgency (24-hour deadline), authority (Security Team), trust (mimics a real security notification format), and a credential-harvesting link. The sender domain has no affiliation with any legitimate institution and was registered four days before the email was sent.

4.2 Sample 02 — Medium Risk (Suspicious)

SAMPLE EMAIL — SUSPICIOUS	
From:	noreply@amazon-support-help.org
Subject:	Your Amazon Order Has Been Delayed
Body:	Dear Customer, Your recent order has been delayed due to a verification issue. Please confirm your delivery address: http://amazon-support-help.org/verify-address

Risk Classification: SUSPICIOUS — MEDIUM RISK | Score: 6 points | 4 indicators detected

The sender domain (amazon-support-help.org) impersonates the Amazon brand without being Amazon's actual domain. DKIM passes because the fake domain signed its own email — this illustrates the important concept that authentication passing for a spoofed domain means nothing. SPF soft-fails, indicating an unauthorized server. The email should not be acted upon without independent verification via amazon.com.

4.3 Sample 03 — Low Risk

LOW Subject: Exclusive Offer For You | From: offers@deals-newsletter.com | Body: 'Hello there, we have an exclusive offer available for a limited time. Visit our website: https://deals-newsletter.com/offer. You can unsubscribe at any time.' | SPF: PASS | DKIM: PASS | DMARC: PASS

Risk Classification: LOW RISK | Score: 2 points | 2 indicators detected

All three authentication protocols pass. The link uses HTTPS and resolves to the same domain as the sender. The only indicators present are a generic greeting and mild urgency language, both consistent with legitimate marketing email. No credential request, no attachment, and no impersonation of a known brand are present.

5. Phishing Indicator Analysis

All detected indicators across the three samples are documented here, organized by category. Each indicator is explained in plain language alongside its risk weight and the specific evidence that triggered the flag.

5.1 Sample 01 — Complete Indicator Breakdown

#	Indicator	Category	Weight	Explanation
1	**Spoofed sender domain**	Sender	**HIGH**	secure-account-verify.com has no affiliation with any legitimate institution. Registered 4 days before the email was sent.
2	**SPF: FAIL**	Sender	**HIGH**	Originating server (45.33.32.156, Eastern Europe) is not authorized for this domain. Email is not from who it claims.
3	**DKIM: FAIL**	Sender	**HIGH**	No valid cryptographic signature present. The email's authenticity cannot be verified.
4	**DMARC: FAIL**	Sender	**HIGH**	Domain policy violated. While p=NONE means no auto-rejection, the failure still confirms a spoofed sending infrastructure.
5	**Malicious HTTP link**	Link	**HIGH**	http://secure-account-verify.com/login uses HTTP (no certificate), belongs to a fake domain, and leads to credential harvesting.
6	**Urgency language**	Content	**MEDIUM**	'Within 24 hours', 'immediately' — artificial deadline designed to prevent the victim from pausing to verify.
7	**Fear language**	Content	**MEDIUM**	'Permanent account lock', 'suspicious activity' — triggers panic to override rational judgment.
8	**Generic greeting**	Content	**MEDIUM**	'Dear User' — no registered name used, confirming this is a mass campaign with no knowledge of the individual target.
9	**Vague threat**	Content	**LOW**	No specific transaction, date, time, or account number mentioned. A real security alert always includes account-specific details.
10	**Unusual send time**	Metadata	**LOW**	Sent at 02:14 AM local time. Phishing campaigns are often sent overnight to reduce filter scrutiny and catch users off guard.

5.2 Cross-Sample Patterns

Examining all three samples together reveals consistent structural patterns that appear in phishing attacks across all risk levels.

Generic greetings appeared in all three samples. The absence of a recipient's registered name is the single most universal phishing indicator in this analysis. It confirms that mass-sent

campaigns do not have access to the target's account information — something a legitimate company always has.

Risk scales directly with the number of combined tactics. Sample 01 layers fear, urgency, authority, domain spoofing, and credential harvesting simultaneously. The combination of multiple tactics — not any single indicator — is what elevates an email to confirmed phishing status. Sample 03 has generic language but no dangerous link, no impersonation, and passing authentication, which keeps it at Low Risk despite sharing some surface characteristics with the phishing samples.

Authentication failures are technically definitive. When SPF, DKIM, and DMARC all fail simultaneously, as in Sample 01, this provides technical confirmation independent of any subjective content analysis. An email can fail authentication even if it reads professionally and contains no obvious grammar errors.

6. Risk Classification

A consistent, point-based scoring framework was applied to all three samples. This framework ensures that risk verdicts are objective, reproducible, and defensible — any analyst following the same steps with the same indicators would arrive at the same classification.

6.1 Scoring Framework

Condition	Points	Category
HIGH indicator: spoofed domain, malicious link, credential request, auth fail	**+3 pts each**	Per indicator
MEDIUM indicator: urgency language, free email provider, generic greeting, HTTP link	**+2 pts each**	Per indicator
LOW indicator: grammar errors, unusual send time, minor formatting anomalies	**+1 pt each**	Per indicator
Total 0–3 points	**LOW RISK**	
Total 4–7 points	**SUSPICIOUS**	
Total 8+ points	**PHISHING**	
Override: any confirmed malicious payload or known malicious URL detected	**Force PHISHING**	

6.2 Classification Results

Sample	Subject	Score	Risk	Override?
01	Urgent: Your Account Will Be Locked	**14 pts**	**PHISHING**	No (score sufficient)
02	Your Amazon Order Has Been Delayed	**6 pts**	**SUSPICIOUS**	No
03	Exclusive Offer For You	**2 pts**	**LOW RISK**	No

7. How the Attack Works

Understanding the attack from the attacker's perspective removes the mystery from phishing and makes it far easier to train non-technical users to recognise and resist it. The following explanation is written in plain language — it is directly suitable for inclusion in employee awareness communications.

Step 1 The attacker chooses a target: In a mass phishing campaign, the attacker sends the same email to thousands of addresses simultaneously, relying on volume rather than precision. In a spear-phishing attack — a more dangerous and targeted variant — the attacker researches a specific individual or organisation using LinkedIn, company websites, and social media. They learn the target's name, role, colleagues, and recent activity to craft an email that feels personal and credible.

Step 2 A fake identity is constructed: The attacker registers a domain that appears similar to a trusted brand at a quick glance — for example, secure-account-verify.com instead of paypal.com. They configure email server records, set up a fake login page visually identical to the real website, and prepare an email template using the brand's actual logo, fonts, and colour scheme.

Step 3 The phishing email is sent: Using psychological triggers — primarily fear and urgency — the attacker sends the email from the fake domain. The email is designed to make the recipient panic and act without thinking. The entire message is engineered to get one action: a click on the malicious link.

Step 4 The victim clicks the link: If the victim does not check the sender address or hover over the link to verify its destination, they click through to the fake login page. The page looks completely real. They enter their username and password — which are captured by the attacker in real time and logged to a remote server.

Step 5 Credentials are stolen and exploited: The attacker now has the victim's login credentials. They log in to the real account immediately, change the password to lock the victim out, and begin their attack — stealing money, harvesting data, or using the compromised account as a trusted platform to launch further phishing attacks on the victim's colleagues.

Step 6 The damage propagates: A single compromised account can cascade. The attacker now has access to the victim's contacts, email history, and the trust that comes with a real address. Emails sent from a genuine, known address have much higher click rates — enabling the attack to spread rapidly through an organisation before IT teams are aware anything is wrong.

KEY INSIGHT The entire attack relies on the victim not taking one extra second to verify. The single most effective defence is a simple habit: hover over any link before clicking. If the URL shown in the status bar does not match the claimed sender's domain, stop.

8. Prevention Tips for Users

The following tips are written for employees at any technical level. Each one is actionable, specific, and explained with a real-world example. This content is designed to be extracted directly into employee awareness communications, intranet pages, or training materials.

01 Check the actual email address — not just the display name

Your email client shows a friendly display name like 'PayPal Security'. Always click that name to reveal the real email address behind it. If the address is from a free provider like @gmail.com or an unfamiliar domain, treat it as suspicious immediately.

Example: Display name: 'HDFC Bank Alert' — Actual address: hdfcalert99@outlook.com

02 Hover over every link before you click it

On desktop, hover your mouse over any link without clicking. The real destination URL appears at the bottom of your browser or email client. If that URL does not match the claimed brand, do not click it under any circumstances.

Example: 'Verify your PayPal account' link → URL shows: http://pp-secure-verify.net. Do not click.

03 Never log in via a link sent in an email

If any email asks you to log in or verify your account, open a new browser tab and type the website address yourself. Never use a link in an email as your route to a login page — even if the email appears completely legitimate.

Example: Instead of clicking 'Sign in to your account', open a new tab and go to paypal.com directly.

04 Treat urgency and fear as warning signs

Legitimate banks, governments, and platforms do not permanently lock accounts within 24 hours without also calling you. If an email is making you panic or feel rushed — pause. Take a breath. That pause is your most effective defence. Verify the request through a separate channel before taking any action.

Example: Call the organisation's official phone number listed on their real website — not any number in the email.

05 Enable Multi-Factor Authentication on all accounts

Multi-Factor Authentication means that even if an attacker captures your password through phishing, they still cannot access your account without a second factor — a code from your phone or authenticator app. Enable it immediately on email, banking, and all work systems.

Example: MFA would have stopped this attack even if the victim had entered their credentials on the fake site.

06 Verify unusual requests through a different channel

If your apparent CEO emails requesting an urgent wire transfer, or your IT department asks for your password via email, do not reply to the email. Call the person directly on their known mobile number to confirm. This is called out-of-band verification and is standard practice in high-security organisations.

Example: Call your CEO's direct number before actioning any financial request received by email.

07 Report suspicious emails — every single time

Every phishing email you report protects every other person in your organisation. Security teams would rather investigate a hundred false alarms than miss one real attack. If you receive something suspicious, forward it to your IT security team immediately.

Example: A single reported email can prevent an organisation-wide breach from spreading.

08 Keep your software, browser, and operating system updated

Many phishing attacks exploit known vulnerabilities in outdated software to run malicious code automatically when a page loads — without any additional clicks from the victim. Keeping all software updated closes these entry points automatically.

Example: Enable automatic updates on Windows or macOS and your browser to ensure security patches are applied immediately.

9. Do's and Don'ts for Employees

This section is designed as a printable quick-reference card for employees at all levels of technical knowledge. It summarises the core behaviours that determine whether phishing attacks succeed or fail.

DO	DON'T
+ Always check the actual email address behind the sender's display name before acting.	- Never click a link in an email that asks you to log in or verify your account.
+ Hover over every link before clicking to verify the real destination URL.	- Never download an attachment you were not explicitly expecting from a known sender.
+ Type website addresses manually in a new tab instead of using email links.	- Never share your password, OTP, or PIN by email — under any circumstance.
+ Verify unusual financial or credential requests by calling the person directly.	- Never act on urgent email requests without independent verification through a separate channel.
+ Enable Multi-Factor Authentication on all work and personal accounts immediately.	- Never trust an email's display name alone — always check the full sender address.
+ Report suspicious emails to your IT or security team without delay.	- Never open .exe, .zip, or macro-enabled Office files from unexpected senders.
+ Keep your browser, email client, and operating system fully and automatically updated.	- Never reply to a suspicious email asking for more information.
+ Look for HTTPS and a padlock icon in the address bar before entering any login details.	- Never ignore unusual financial requests just because they appear to come from leadership.
+ Trust your instincts — if something feels wrong about an email, stop and verify it separately.	- Never use public Wi-Fi to access work email without a VPN.
+ Complete your organisation's annual phishing awareness and simulation training.	- Never assume an email is safe simply because it passed your spam filter.

9.1 Emergency Response — If You Suspect You Have Clicked a Phishing Link

1. Stop immediately. Do not enter any information on the page that opened.
2. Disconnect from the network. Unplug the Ethernet cable or turn off Wi-Fi on your device.
3. Do NOT turn off your computer. Security teams need the machine running to investigate and preserve forensic evidence.
4. Call your IT Security team immediately using a known phone number — do not email them from the affected machine.
5. Change your passwords from a different, clean device. Prioritise all accounts accessible from the compromised computer.
6. Enable Multi-Factor Authentication on all accounts if not already active.

7. Do not attempt to fix the problem yourself. Let the security team lead the response from this point.

10. Project Deliverables

The following deliverables were produced as outputs of this project. Together they constitute a complete Task 2 submission that covers technical analysis, structured documentation, a client-ready awareness report, and a public code repository.

#	Deliverable	Description
1	**PDF Awareness Report**	A professionally formatted, multi-section client-ready PDF report covering the threat overview, full indicator analysis with annotated tables, risk classification results, a plain-language attack explanation, 8 prevention tips with examples, and an employee Do's & Don'ts card. Suitable for distribution to employees and submission to supervisors.
2	**Word Documentation (.docx)**	This document — a comprehensive technical record of the project covering all analysis decisions, methodology, tools, findings, and interpretations. Suitable for submission as a formal internship deliverable.
3	**GitHub Repository**	A public repository containing all evidence files (3 sample emails as .txt with analyst notes, reconstructed email header, header analysis notes, SPF/DKIM/DMARC reference guide), analysis markdown files (indicator findings, risk classification, URL inspection), the PDF report, and a fully structured README.
4	**Learning Materials PDF**	A comprehensive 7-chapter + 2-appendix learning guide covering all technical concepts from beginner to advanced level, including a printable red flag checklist and a 20-term glossary.
5	**Google Antigravity Agent Prompt**	A complete, structured agent prompt enabling automated construction of the full-stack web application version of this system using Python/FastAPI, with 8 features including the phishing indicator engine, header analyzer, risk classifier, and PDF report generator.

10.1 Repository Structure

The public GitHub repository is structured to allow any reader to navigate from evidence to analysis to deliverable without additional explanation.

Path	Contents
`evidence/sample-emails/`	Three phishing email samples (.txt) with embedded analyst notes, plus a JSON metadata file
`evidence/header-analysis/`	Raw email header for Sample 01, header analysis notes, SPF/DKIM/DMARC reference guide
`analysis/`	Indicator findings markdown, risk classification markdown, URL and domain inspection notes
`report/`	Client-ready PDF awareness report
`docs/`	Tools reference guide and end-to-end methodology document

`README.md`	Project overview with badges, tools table, methodology summary, risk classification results, and push instructions

10.2 Key Findings Summary

Social engineering dominates over technical sophistication. All three samples relied primarily on psychological manipulation rather than malware or zero-day exploits. The human layer remains the primary attack surface in email-based threats.

Domain spoofing is the primary deception vector. The high-risk sample used a purpose-registered domain designed to appear legitimate at a quick glance. It was registered four days before the email was sent, carried no SPF record, and failed DKIM authentication entirely.

HTTP links are a definitive red flag. No legitimate financial institution or account management service delivers login pages over an unencrypted HTTP connection. This single indicator alone is sufficient grounds for a Suspicious classification.

Three controls would have the highest organisational impact: DMARC enforcement (p=reject) at the domain level; regular employee phishing simulation training; and Multi-Factor Authentication on all accounts. Any one of these controls in isolation would significantly reduce the success rate of the attacks documented in this analysis.

Disclaimer

All phishing email samples in this project are synthetic examples created for educational purposes. No real credentials, personally identifiable information, or live malicious infrastructure were involved. This project is security education and analysis — not hacking or penetration testing.